

Retail Data Protection & Customer Privacy Policy

Document ID: RDP-001 | Version: 1.0 | Effective Date: January 1, 2026

1. Purpose

This policy establishes standards for the collection, processing, storage, transfer, and protection of customer personal data across retail operations.

2. Scope

Applies to:

- All employees
- Contractors
- Third-party vendors
- All systems processing customer PII

3. Definitions

Personal Data (PII): Any information identifying an individual directly or indirectly.

Sensitive Data: Financial, biometric, or health-related information.

Processing: Collection, storage, use, sharing, deletion.

4. Customer PII Handling

4.1 Data Minimization

Only data strictly required for business operations may be collected.

4.2 Purpose Limitation

PII shall be processed solely for defined, documented business purposes.

4.3 Encryption

All customer PII must be encrypted at rest and in transit.

4.4 Access Controls

Access shall be restricted using role-based access controls (RBAC).

5. Consent Management

5.1 Explicit Consent

Consent must be obtained before processing personal data where legally required.

5.2 Withdrawal of Consent

Customers may withdraw consent at any time.

5.3 Consent Records

Consent logs must be retained for audit purposes.

6. Data Sharing Restrictions

6.1 Third-Party Sharing

Data may only be shared with approved vendors under signed Data Processing Agreements (DPA).

6.2 Cross-Border Transfers

Transfers outside primary operating jurisdiction require:

- Legal basis validation
- Standard contractual safeguards
- Compliance review approval

7. Data Breach Obligations

7.1 Incident Reporting

Security incidents involving PII must be reported within 24 hours.

7.2 Notification

Regulatory notification must occur within legally mandated timeframes.

7.3 Post-Incident Review

Root cause analysis and corrective actions required.

8. Compliance & Enforcement

Violations may result in disciplinary action and contractual termination.